



MEDICONNECT

Rapport de projet

RGPD

Plateforme sécurisée de recrutement

Groupe 9

Mahereiti TERAIAMANO

Yassine MOUMOUN

Mahdi EL BICHARI

Sara EDIRI

Date : 14/01/2026

Sommaire

I. Contexte et objectifs	3
II. Conception de l'architecture réseau	3
1. Architecture basique	3
2. Sécurisation avec un pare-feu	4
III. Installation et configuration d'un serveur LAMP	5
1. Installation d'Apache2	5
2. Installation de PHP	5
3. Installation de MariaDB	6
4. Attribution d'une adresse IP statique au serveur LAMP	7
5. Installation du serveur NextCloud	7
IV. Création du site web et du formulaire sécurisé	11
1. Architecture de l'application	11
2. Interface publique et formulaire de candidature	11
V. Gestion des droits et journalisation	14
3. Système d'authentification	14
1. Processus de vérification	15
2. Gestion des sessions	15
3. Tableaux de bords administratifs	15
4. Base de données et journalisation	17
5. Sécurisation	18
VI. Rédaction du PIA	20
1. Contexte	20
2. Principes fondamentaux	20
3. Les risques	21
4. La cartographie des risques	23
VII. Synthèse	24

I. Contexte et objectifs

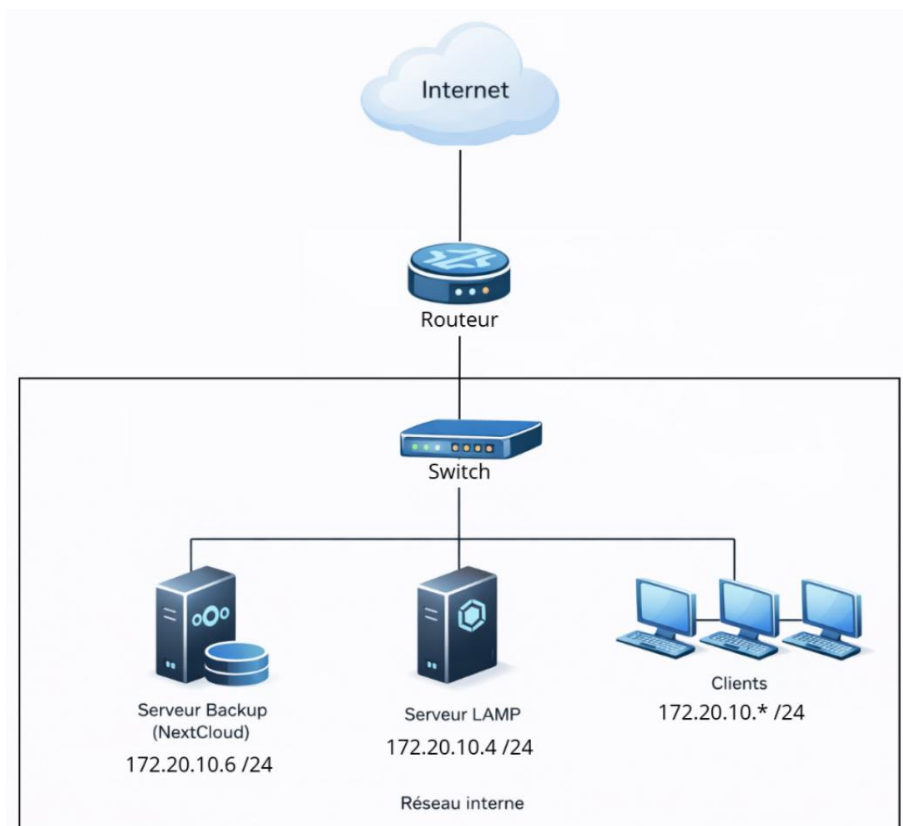
Ce projet a pour objectif de mettre en place une plateforme de recrutement sécurisée pour l'entreprise MEDICONNECT. Celle-ci doit permettre aux candidats de déposer leurs informations personnelles en ligne tout en respectant le Règlement Général sur la Protection des Données. Lors de ce TP, on a conçu une architecture réseau adaptée, installé un serveur LAMP, développé un formulaire sécurisé de candidature, définit les droits d'accès, et fait une analyse d'impact (PIA).

II. Conception de l'architecture réseau

1. Architecture basique

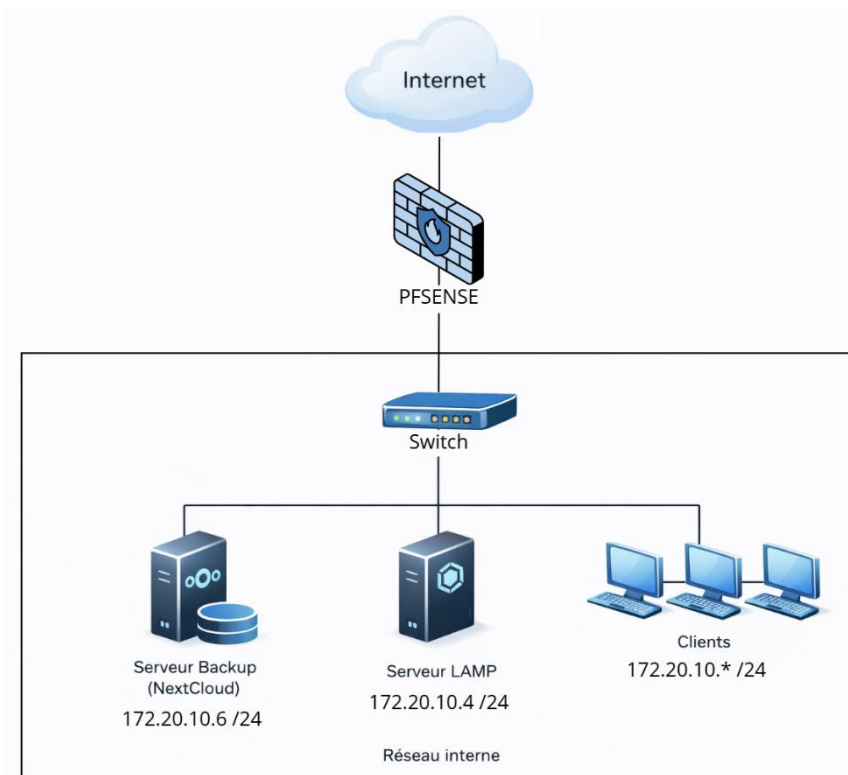
Pour le projet MEDICONNECT, nous avons mis en place une architecture réseau simple comprenant :

- Un serveur LAMP pour héberger le formulaire et la base de données.
- Un serveur Backup *NextCloud* pour sauvegarder les données du serveur LAMP.
- Des PC qui correspondent aux employés.
- Un switch pour relier les différents éléments du réseau interne.
- Un routeur pour connecter le réseau interne à internet.



2. Sécurisation avec un pare-feu

Pour améliorer la sécurité du réseau, on remplace le routeur par PFSENSE, qui joue le rôle de routeur et de pare-feu.



a. Configuration de PFSENSE :

a) Règles d'accès

On met en place des règles d'accès pour limiter les droits des utilisateurs.

- Le compte administrateur a un accès complet aux serveurs et aux configurations (*droits admin*).
- Le service RH accède uniquement aux candidatures (lecture et exportation).
- Les candidats ont un accès limité au formulaire pour déposer leur candidature.

b) Filtrage entrant / sortant

Le pare-feu filtre le trafic réseau entrant et sortant. En entrée, on autorise seulement les ports nécessaires au serveur web (HTTP(80) et HTTPS (443)). Et en sortie, on autorise seulement le trafic nécessaire.

c) Prévention contre quelques attaques courantes

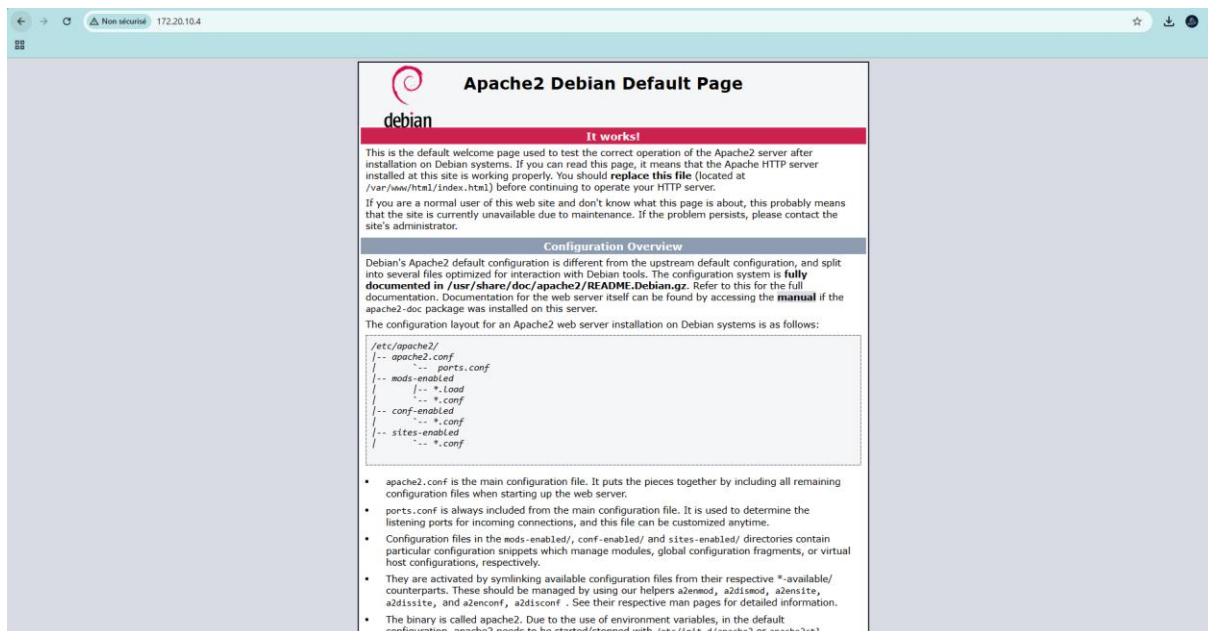
On devrait aussi mettre en place certaines mesures de protection contre quelques attaques courantes :

- Les attaques DDOS : en limitant le nombre de requête vers le service web dans un certain délai et en bloquant les adresses IP suspectes.
- Les scans (ou analyse de ports) : en bloquant tous les ports inutiles.
- Les attaques par injection SQL : en utilisant des requêtes préparées dans le formulaire, et en validant les données côté serveur pour empêcher l'exécution de requêtes imprévues.

III. Installation et configuration d'un serveur LAMP

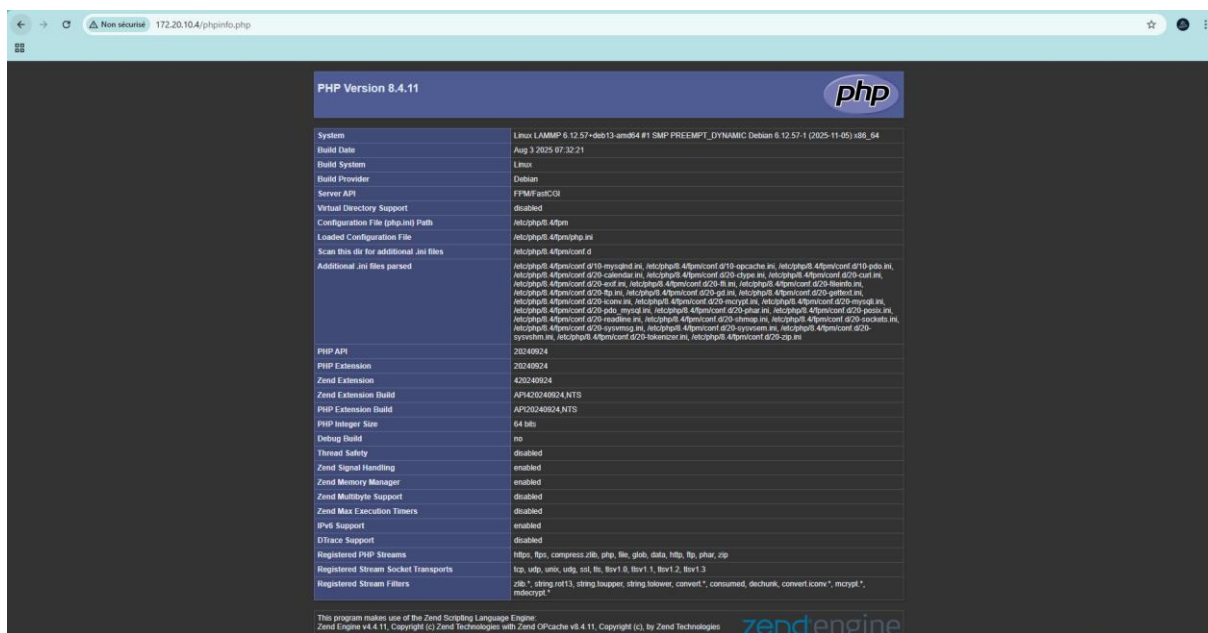
1. Installation d'Apache2

Une fois *Debian* installé, on a installé *Apache2* pour mettre en place un serveur web capable d'afficher des pages en *http*. Après son installation, on obtient la page web par défaut d'*apache2* qui confirme l'installation du serveur web et le fonctionnement du service HTTP.



2. Installation de PHP

Ensuite on a installé PHP pour pouvoir exécuter des pages dynamiques. Grâce à *phpinfo()*, on a vérifié que PHP est bien installé et bien intégré à Apache.



Configuration

calendar

Calendar support	enabled	
------------------	---------	--

cgi-fcgi

php-fpm	active	
---------	--------	--

Directive	Local Value	Master Value
cgi.disable_path	Off	Off
cgi.fix_pathinfo	On	On
cgi.force_redirect	On	On
cgi.ngsl	Off	Off
cgi.redirect_status_err	no value	no value
cgi.rfc2616_headers	Off	Off
fastcgi.error_header	no value	no value
fastcgi.logging	On	On
fpm.config	no value	no value

Core

PHP Version	8.4.11	
-------------	--------	--

Directive	Local Value	Master Value
allow_url_fopen	On	On
allow_url_include	Off	Off
arg_separator.input	&	&
arg_separator.output	&	&
auto_append_file	no value	no value
auto_globals_jit	On	On
auto_prepend_file	no value	no value
browscap	no value	no value
default_charset	UTF-8	UTF-8
default_mimetype	text/html	text/html
disable_classes	no value	no value
disable_functions	no value	no value
display_errors	Off	Off
display_startup_errors	Off	Off
doc_root	no value	no value

3. Installation de MariaDB

Enfin, on a installé MariaDB comme système de gestion de base de données. On a vérifié son fonctionnement en affichant la version installée (via `mariadb -v`), en se connectant à MariaDB (via `mariadb -u root -p`), et en listant les bases par défaut (via `show database`). Le redémarrage du service (via `systemctl restart mariadb`) a permis de confirmer que tout fonctionne bien après configuration.

```
The operation might have been successful, or it might have not done anything.

Reloading the privilege tables will ensure that all changes made so far
will take effect immediately.

Reload privilege tables now? [Y/n] Y
... Success!

Cleaning up...

All done! If you've completed all of the above steps, your MariaDB
installation should now be secure.

Thanks for using MariaDB!
root@LAMMP:/home/aaa# mariadb -v
mariadb from 11.8.3-MariaDB, client 15.2 for debian-linux-gnu (x86_64) using EditLine wrapper
root@LAMMP:/home/aaa# apt policy mariadb-server
mariadb-server:
  Installed: 1:11.8.3-0+deb13u1
  Candidate: 1:11.8.3-0+deb13u1
  Version table:
 *** 1:11.8.3-0+deb13u1 500
      500 http://deb.debian.org/debian trixie/main amd64 Packages
      100 /var/lib/dpkg/status
root@LAMMP:/home/aaa# mariadb -u root -p
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 47
Server version: 11.8.3-MariaDB-0+deb13u1 from Debian -- Please help get to 10k stars at https://github.com/MariaDB/Server

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> show databases;
+-----+
| Database |
+-----+
| information_schema |
| mysql |
| performance_schema |
| sys |
+-----+
4 rows in set (0.001 sec)

MariaDB [(none)]> exit
Bye
root@LAMMP:/home/aaa# systemctl restart mariadb
root@LAMMP:/home/aaa#
```

4. Attribution d'une adresse IP statique au serveur LAMP

Pour garantir la disponibilité et l'accessibilité permanente des services hébergés (Apache, MySQL, PHP) sur le serveur LAMP, on a configuré une adresse IP statique sur l'interface réseau *enp0s3*. Concrètement, on a édité le fichier */etc/network/interfaces* pour remplacer la configuration DHCP par une configuration fixe *auto enp0s3* et *iface enp0s3 inet static* suivis des paramètres *address 172.20.10.2*, *netmask 255.255.255.0*, *gateway 172.20.10.1*, ainsi que *dns-domain nuc* et *dns-nameservers 172.20.10.1 1.1.1.1 8.8.8.8*. On a laissé l'IPv6 en mode autoconfig (*iface enp0s3 inet6 auto*). Après sauvegarde, on a appliqué la nouvelle configuration (via *ifdown/ifup* ou redémarrage du service réseau) et vérifié l'adresse avec *ip addr show*. Cette modification assure une adresse stable pour la redirection de ports, les enregistrements DNS, les certificats SSL et la gestion du pare-feu, facilitant la maintenance et l'accès fiable aux services LAMP.

```
GNU nano 8.4 /etc/network/interfaces
# This file describes the network interfaces available on your system
# and how to activate them. For more information, see interfaces(5).

source /etc/network/interfaces.d/*

# The loopback network interface
auto lo
iface lo inet loopback

# The primary network interface
#allow-hotplug enp0s3
#iface enp0s3 inet dhcp

auto enp0s3
iface enp0s3 inet static
    address 172.20.10.2
    netmask 255.255.255.0
    gateway 172.20.10.1
    dns-domain nuc
    dns-nameservers 172.20.10.1 1.1.1.1 8.8.8.8

# This is an autoconfigured IPv6 interface
iface enp0s3 inet6 auto
```

5. Installation du serveur NextCloud

Pour renforcer la sécurité, on a installé et configuré un serveur Nextcloud. Le serveur web exécute l'application, tandis que Nextcloud stocke et sauvegarde les données, ce qui apporte une meilleure isolation, du chiffrement et une gestion centralisée des fichiers.

Pour faire cela, on a d'abord utilisé *MariaDB* pour créer une base de données, attribuer les privilèges à un utilisateur et l'actualisation des droits. Ensuite, on a téléchargé l'archive *Nextcloud 22.2.3* depuis le site officiel avec la commande *wget*.

```

Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 31
Server version: 11.8.3-MariaDB-0+deb13u1 from Debian -- Please help get to 10k stars at https://github.com/MariaDB/Server

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> CREATE DATABASE nextcloudodb;
Query OK, 1 row affected (0.001 sec)

MariaDB [(none)]> GRANT ALL ON nextcloudodb.* TO 'usernextcloud'@'localhost' IDENTIFIED BY 'password';
Query OK, 0 rows affected (0.005 sec)

MariaDB [(none)]> FLUSH PRIVILEGES;
Query OK, 0 rows affected (0.003 sec)

MariaDB [(none)]> EXIT;
Bye
root@NextCloud:~/home/aaa# cd /tmp
root@NextCloud:~/tmp# wget https://download.nextcloud.com/server/releases/nextcloud-22.2.3.zip
--2025-12-12 15:09:28-- https://download.nextcloud.com/server/releases/nextcloud-22.2.3.zip
Resolving download.nextcloud.com (download.nextcloud.com)... 5.9.202.145, 2a01:4f8:210:21c0::145
Connecting to download.nextcloud.com (download.nextcloud.com)|5.9.202.145|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 159413572 (152M) [application/zip]
Saving to: 'nextcloud-22.2.3.zip'

nextcloud-22.2.3.zip          100%[=====]
2025-12-12 15:09:41 (12.4 MB/s) - 'nextcloud-22.2.3.zip' saved [159413572/159413572]

```

En essayant d'accéder à l'interface web de *Nextcloud*, un message d'erreur s'affiche indiquant une incompatibilité entre la version de *Nextcloud* installée et la version de PHP utilisée sur le serveur (PHP 8.4.11).

This version of Nextcloud is not compatible with > PHP 8.0.
You are currently running 8.4.11.

Pour résoudre ce problème, on a mis en place une machine virtuelle *Nextcloud*. Les informations système et réseau (nom d'hôte, interfaces réseau, adresses IPv4 et IPv6) confirment le bon fonctionnement de la VM, qui servira de base pour l'installation et la configuration de *Nextcloud*.

```

vm 2 [En fonction] - Oracle VirtualBox
Fichier  Machine  Écran  Entrée  Périphériques  Aide
-----
Welcome to the first setup of your own Nextcloud Server! :)

To run the startup script type the sudoer password, then hit [ENTER].
The default sudoer password is: nextcloud

You will now setup the basics of the server.
A working internet connection is recommended, but not needed for the
setup to finish properly.

To choose the defaults during installation, just hit [ENTER].

##### Nextcloud - 2026 #####
[sudo] password for ncadmin:

```



```

https://github.com/nextcloud/vm

ostname: nextcloud
AN IPv4: 92.184.123.6
AN IPv6: 2a01:cb0d:a00c:7978:a00:27ff:febb:97b9
AN IPv4: 10.30.176.58

cadmin@nextcloud:~$ ip a
object "q" is unknown, try "ip help".
cadmin@nextcloud:~$ ip a
: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
: enp0s17: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:bb:97:b9 brd ff:ff:ff:ff:ff:ff
    inet 10.30.176.58/24 brd 10.30.176.255 scope global dynamic enp0s17
        valid_lft 3486sec preferred_lft 3486sec
    inet6 2a01:cb0d:a00c:7978:a00:27ff:febb:97b9/64 scope global dynamic mngtmpaddr noprefixroute
        valid_lft 7089sec preferred_lft 7089sec
    inet6 fe80::a00:27ff:febb:97b9/64 scope link
        valid_lft forever preferred_lft forever
cadmin@nextcloud:~$
```

L'installation de *Nextcloud* sur la VM s'est ensuite déroulée sans problème. À la fin, les informations nécessaires pour accéder au service ont été affichées (adresse IP du serveur et nom d'hôte). On a pu redémarrer le système pour appliquer toutes les configurations et rendre l'interface web accessible.

```

Nextcloud VM - 2025 - Nextcloud Startup Script

Congratulations! You have successfully installed Nextcloud

LOGIN:
Login to Nextcloud in your browser:
- IP: 172.20.10.6
- Hostname: nextcloud

## PLEASE PRESS OK TO REBOOT. ##

<Ok>
```

Lors de l'initialisation de *Nextcloud*, un compte administrateur a été automatiquement créé. On a utilisé les identifiants associés à ce compte pour se connecter une première fois à l'interface web afin d'effectuer les opérations d'administration, comme la gestion des utilisateurs et la configuration du service. Pour des raisons de sécurité, on a ensuite modifié le mot de passe.

```

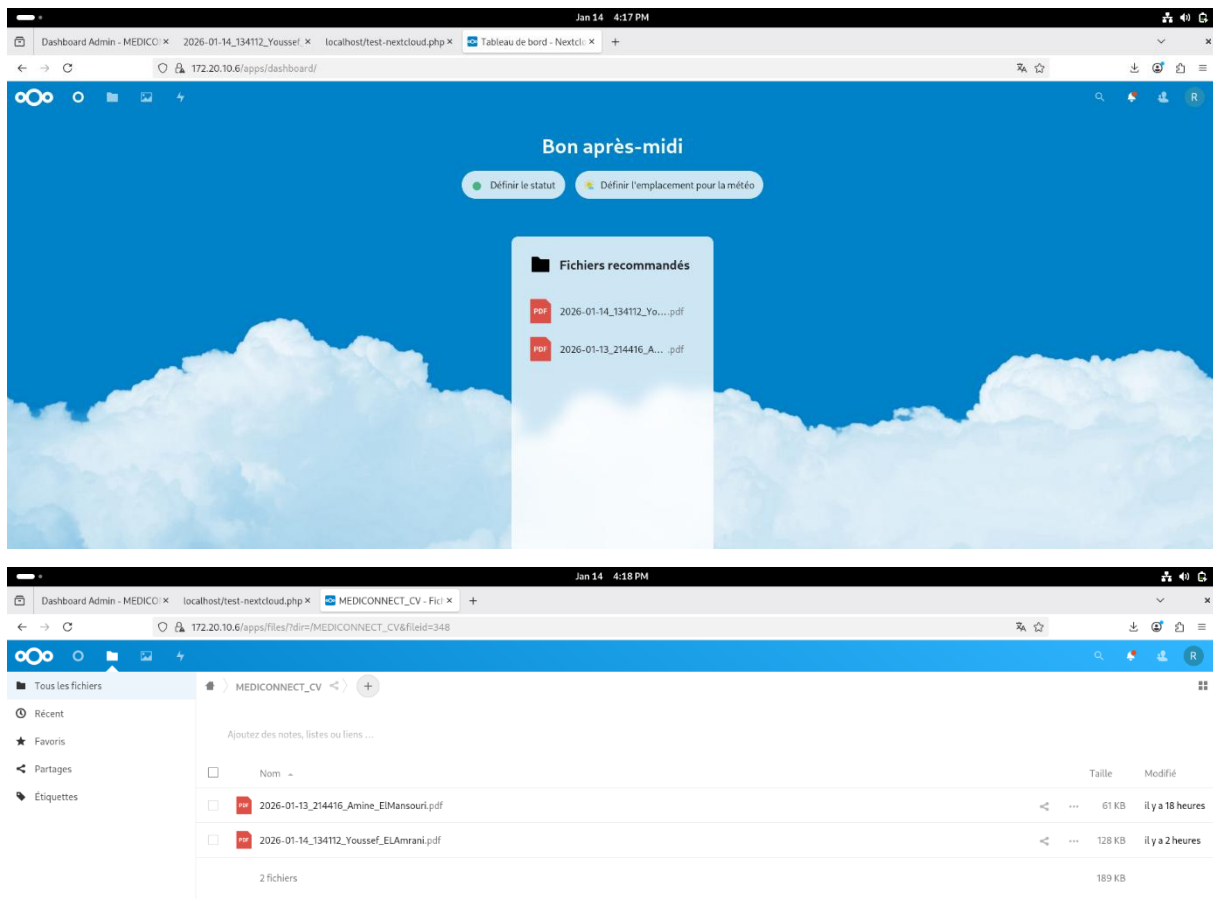
Nextcloud VM - 2025 - Nextcloud Startup Script

The new Web Admin in Nextcloud is now: RGPD
The password is set to: MIDOUMIDOU22

This is used when you login to Nextcloud itself, i.e. on the

<Ok>
```

Enfin, le fonctionnement de *Nextcloud* a été validé par une connexion réussie à l'interface web. Le compte administrateur permet l'administration complète de la plateforme et confirme que la mise en service du système est opérationnelle.



Cette capture montre l'édition du fichier **/etc/fstab** avec *nano*. Ce fichier définit les systèmes de fichiers montés automatiquement au démarrage. On y observe les entrées utilisant des identifiants **UUID**, garantissant un montage fiable des partitions indépendamment de l'ordre des disques. Les lignes présentes indiquent le point de montage de la partition racine (/), de la partition /boot ainsi que de l'espace d'échange (*swap*). Cette configuration assure la persistance du montage des volumes nécessaires au bon fonctionnement du système et constitue une étape essentielle pour garantir la disponibilité du stockage utilisé par les services, notamment Nextcloud, après chaque redémarrage.

```

GNU nano 4.8 /etc/fstab Modified
# /etc/fstab: static file system information.
#
# Use 'blkid' to print the universally unique identifier for a
# device; this may be used with UUID= as a more robust way to name devices
# that works even if disks are added and removed. See fstab(5).
#
# <file system> <mount point> <type> <options> <dump> <pass>
# / was on /dev/ubuntu-vg/ubuntu-lv during curtin installation
/dev/disk/by-id/dm-uuid-LVM-Cvbj2qVNehKHU1dzNCrK1WYbQIJkEd3rWpQlayNgTRYreNmYiuYxiGLNsKBiZXXkd / ext4
# /boot was on /dev/sda2 during curtin installation
/dev/disk/by-uuid/54bc09e5-b06a-4898-93af-a6f21dd68345 /boot ext4 defaults 0 0
/swap.img none swap sw 0 0

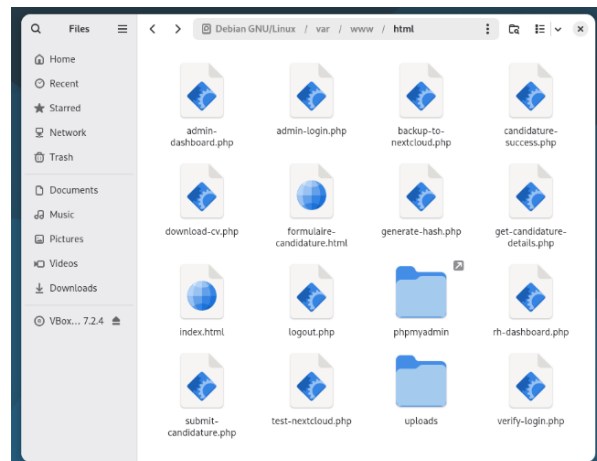
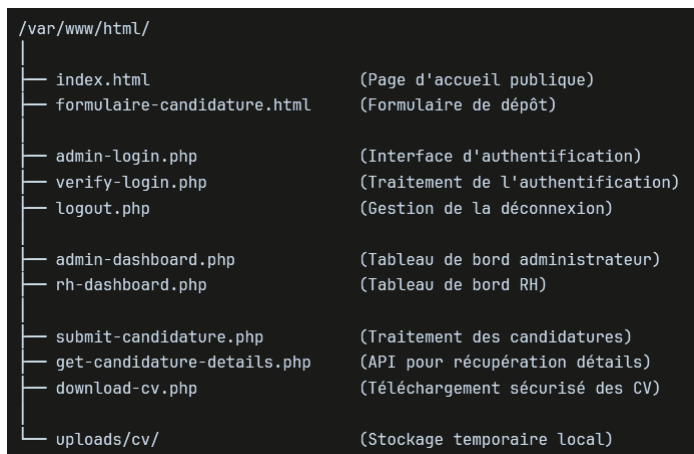
```

Afin d'assurer la sauvegarde régulière des fichiers du serveur LAMP vers le serveur Nextcloud, nous utilisons l'outil **rsync**, qui permet une synchronisation incrémentielle rapide et fiable. La commande `rsync -avz /var/www/html/formulaires/ /mnt/nextcloud/` permet de copier uniquement les fichiers modifiés depuis le répertoire source vers le répertoire de destination. Pour automatiser cette opération, on a configuré une tâche planifiée à l'aide de **cron** via la commande `crontab -e`, qui permet d'exécuter la synchronisation à intervalles réguliers sans intervention manuelle, garantissant ainsi que les données restent à jour et sécurisées.

IV. Création du site web et du formulaire sécurisé

1. Architecture de l'application

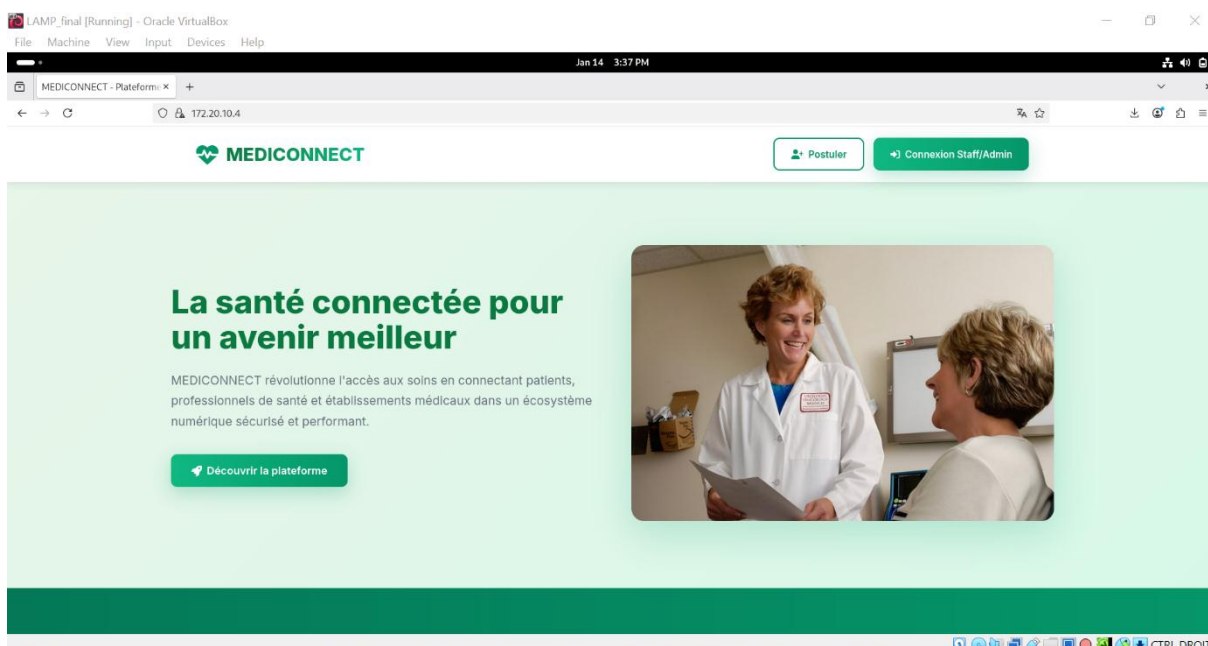
L'application repose sur une architecture client-serveur utilisant la stack LAMP. La structure des fichiers suit une organisation modulaire : les fichiers HTML assurent l'affichage côté client, tandis que les fichiers PHP exécutent la logique serveur, communiquent avec la base de données et contrôlent les accès selon les rôles. Cette séparation entre présentation et logique métier facilite la maintenance et l'évolution du code.



2. Interface publique et formulaire de candidature

On a développé plusieurs pages web qui constituent l'interface de l'application.

- La page d'accueil, développée en HTML5 et CSS3, présente un design moderne avec une palette verte évoquant le domaine médical. Elle propose deux actions principales : un bouton pour postuler et un bouton pour accéder à l'espace administrateur, séparant clairement les accès publics et restreints.



150+

Établissements partenaires

2,500+

Professionnels de santé

75,000+

Patients connectés

24/7

Support disponible

Nos Services

Des solutions innovantes pour une santé connectée



Gestion des Patients

Dossiers médicaux électroniques sécurisés, historique complet et suivi personnalisé pour chaque patient.



Rendez-vous en Ligne

Planification intelligente des consultations avec gestion automatique des disponibilités et rappels.



Pharmacie Connectée

Ordonnances électroniques sécurisées et gestion en temps réel des stocks de médicaments.



Téléconsultation

Consultations médicales à distance en haute qualité avec partage de documents sécurisé.



Sécurité Maximale

Cryptage de niveau bancaire et conformité RGPD pour protéger vos données de santé.



Analyses & Rapports

Tableaux de bord intelligents et rapports détaillés pour un suivi optimal des performances.

Pourquoi choisir MEDICONNECT ?

Une technologie de pointe au service de la santé

Technologie de Pointe

Notre plateforme utilise les dernières innovations en intelligence artificielle et cloud computing pour garantir des performances optimales et une disponibilité 24/7.

Interface intuitive, traitement rapide des données et intégration fluide avec tous vos systèmes existants.



Professionnels Qualifiés

Collaborez avec un réseau de plus de 2,500 professionnels de santé certifiés et expérimentés. Chaque praticien est rigoureusement vérifié et validé.

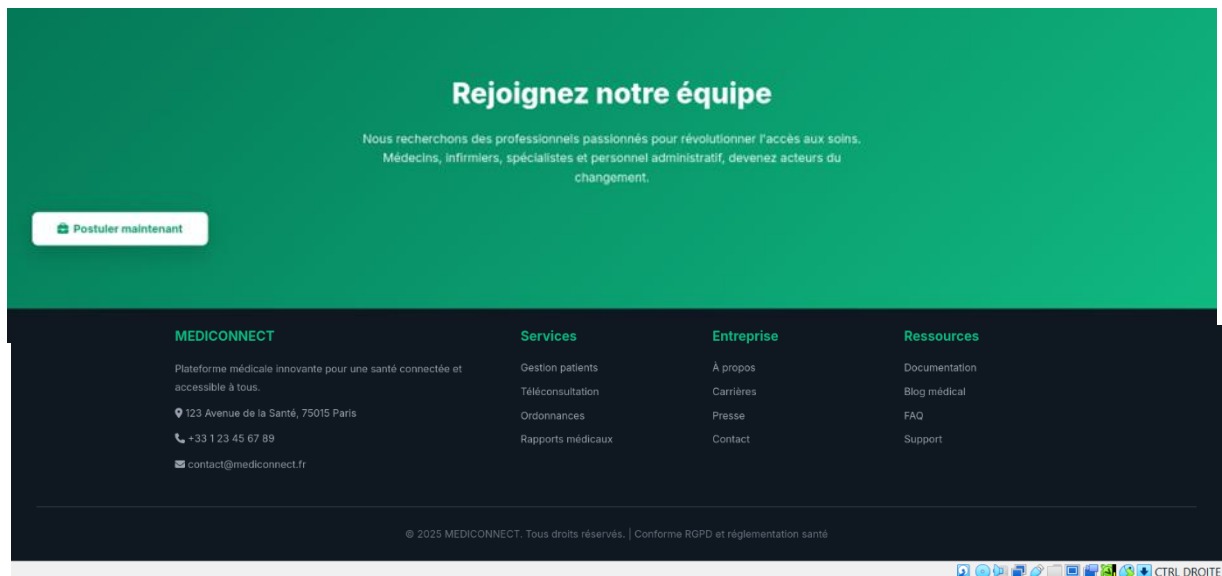
Médecins généralistes, spécialistes, infirmiers et psychologues - tous dédiés à offrir les meilleurs soins possibles.

Sécurité & Confidentialité

Vos données de santé sont notre priorité absolue. Nous utilisons un cryptage de niveau bancaire et respectons strictement toutes les réglementations en vigueur.

Hébergement certifié HDS (Hébergeur de Données de Santé), conformité RGPD et audits de sécurité réguliers.

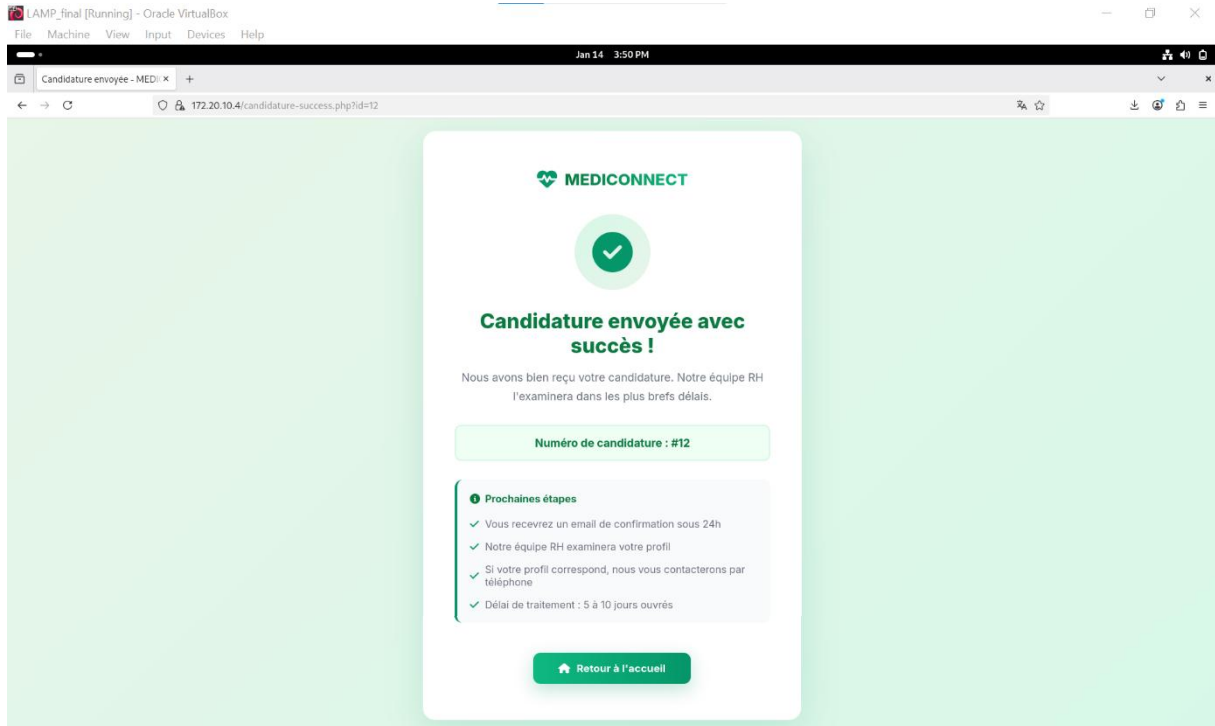




- Le formulaire de candidature comprend plusieurs sections : identité (nom, prénom, date et lieu de naissance), informations personnelles (diplôme, adresse, numéro de sécurité sociale), contact (email, téléphone - champs obligatoires) et upload du CV (PDF, DOC ou DOCX) :

Le formulaire transmet les données vers le script submit-candidature.php. Ce script vérifie que tous les champs obligatoires sont remplis, que le mail est valide, et que le CV a le bon format et la bonne taille. Ensuite, les données sont nettoyées pour éviter les risques, et enregistrées dans la base de données.

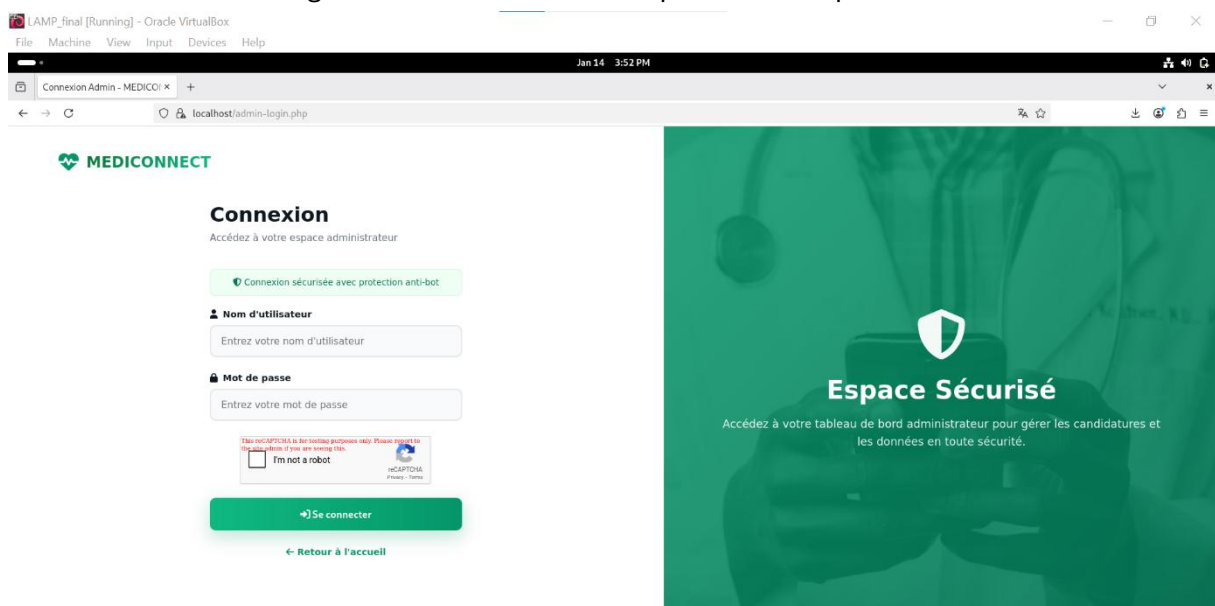
- La page de confirmation affiche un message de succès avec un numéro de suivi unique.



V. Gestion des droits et journalisation

3. Système d'authentification

L'accès aux fonctionnalités de gestion des candidatures nécessite une authentification préalable. Pour cela, on a développé une page de connexion dédiée. Tous les utilisateurs (administrateur, membre de la RH..) se connectent via la même page. Cela simplifie l'utilisation tout en maintenant une gestion des droits automatique en arrière-plan selon leur rôle.



1. Processus de vérification

Lorsqu'un utilisateur envoie ses identifiants, les données sont transmises au script `verify-login.php`. Celui-ci se connecte de manière sécurisée à la base de données, cherche l'utilisateur avec une requête préparée pour éviter les injections SQL, et vérifie le mot de passe grâce à `password_verify()` de PHP qui compare le mot de passe saisi avec le mot de passe stocké sous forme de hash. Si tout est correct, une session PHP est créée avec les informations de l'utilisateur, notamment son rôle (admin, RH..) qui servira à déterminer les actions autorisées.

Le script enregistre aussi cette connexion dans une table de logs, en notant l'heure de connexion et l'adresse IP de l'utilisateur. Enfin, le script redirige l'utilisateur vers le tableau de bord correspondant à son rôle (`admin-dashboard.php` ou `rh-dashboard.php`).

Utilisateur	verify-login.php	Base de données
----(1) POST login----->		
	----(2) SELECT user----->	
	<---(3) Hash + rôle-----	
	--(4) password_verify()	
<--(5) Redirection-----		
vers dashboard		

2. Gestion des sessions

Chaque page protégée vérifie qu'une session est active, sinon, l'utilisateur est automatiquement redirigé vers la page de connexion. Cette vérification systématique empêche tout accès non autorisé. Pour se déconnecter, l'utilisateur dispose d'un bouton présent dans l'en-tête de chaque page protégée. Ce bouton appelle `logout.php`, qui supprime la session, enregistre l'action dans les logs, et redirige l'utilisateur vers la page de connexion.

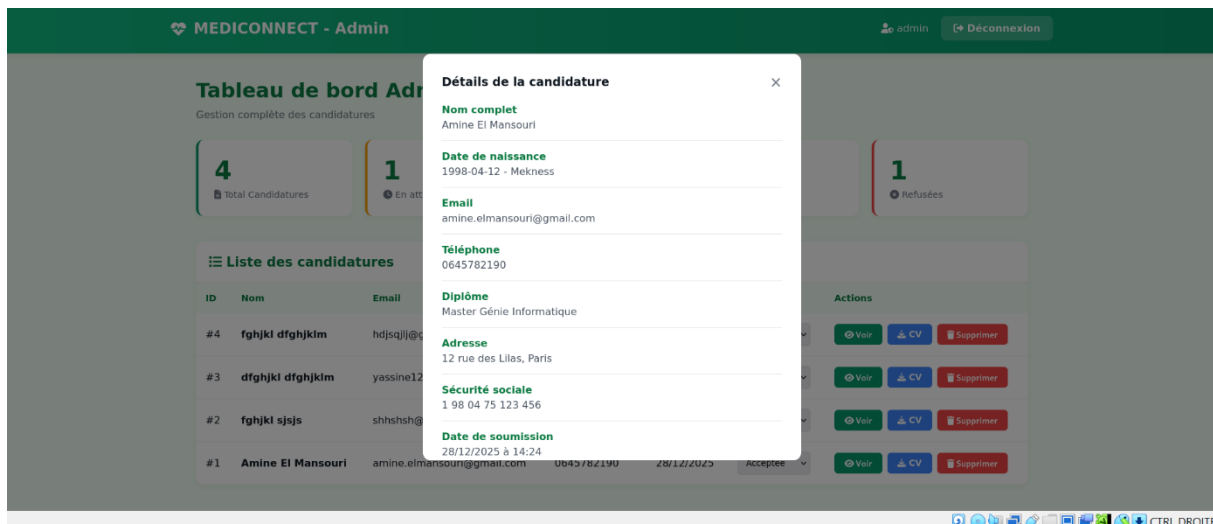
3. Tableaux de bords administratifs

Après connexion, l'utilisateur arrive sur un tableau de bord adapté à son rôle. On a développé deux interfaces distinctes pour répondre aux différents besoins des administrateurs et du service RH.

- Tableau de bord administrateur (gestion complète)

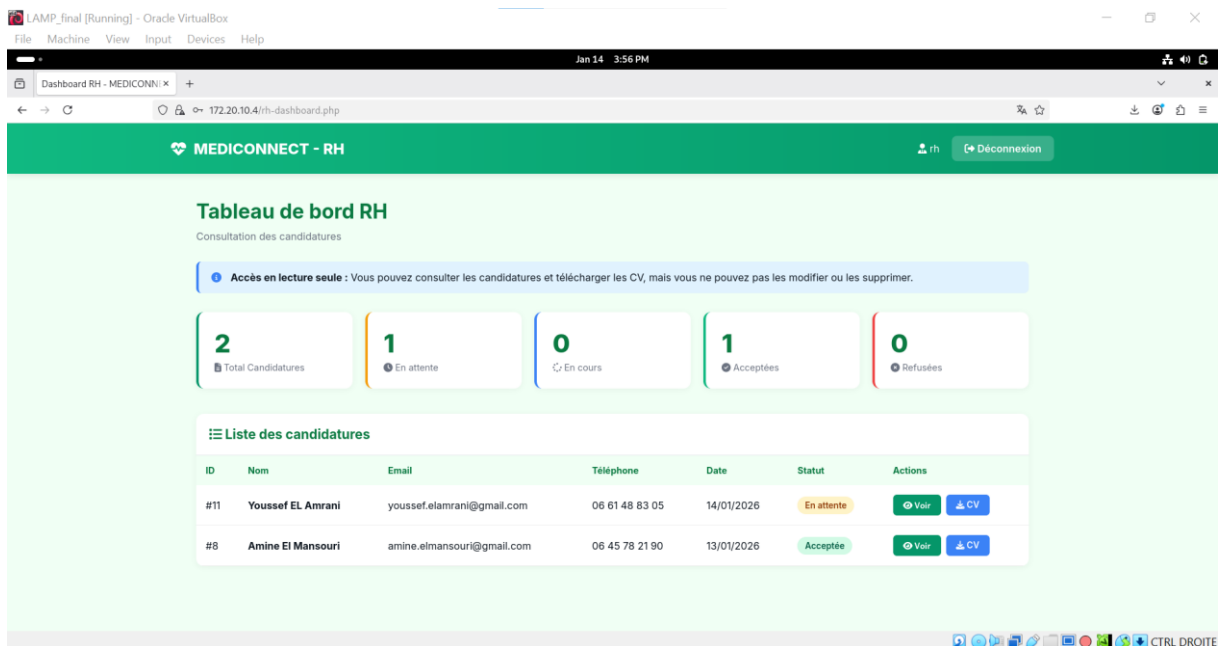
The screenshot displays the 'Tableau de bord Administrateur' for MEDICONNECT. It features a green header with the user's name 'admin' and a 'Déconnexion' button. The main content area shows five summary cards for candidate management: Total Candidatures (2), En attente (1), En cours (0), Acceptées (1), and Refusées (0). Below these is a table titled 'Liste des candidatures' with columns for ID, Nom, Email, Téléphone, Date, Statut, and Actions. The table lists two candidates: Youssef EL Amrani and Amine El Mansouri.

ID	Nom	Email	Téléphone	Date	Statut	Actions
#11	Youssef EL Amrani	youssef.elamrani@gmail.com	06 61 48 83 05	14/01/2026	En attente	Voir CV Supprimer
#8	Amine El Mansouri	amine.elmansouri@gmail.com	06 45 78 21 90	13/01/2026	Acceptée	Voir CV Supprimer



Il affiche l'identité de l'utilisateur et un bouton de déconnexion. Des cartes colorées présentent les statistiques : total des candidatures, en attente, en cours, acceptées et refusées. Le tableau principal liste toutes les candidatures avec ID, nom, mail, téléphone, date et statut. L'administrateur peut consulter les détails dans une fenêtre modale, télécharger le CV (via download-cv.php), modifier le statut via un menu déroulant, et supprimer la candidature avec son CV après confirmation.

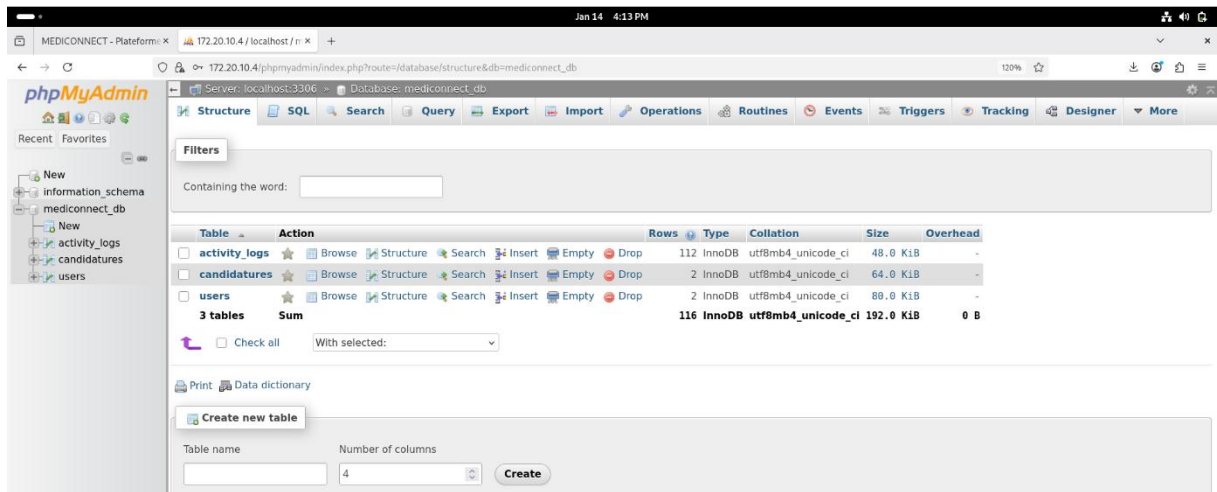
- Tableau de bord RH (lecture seule et téléchargement des candidatures) :



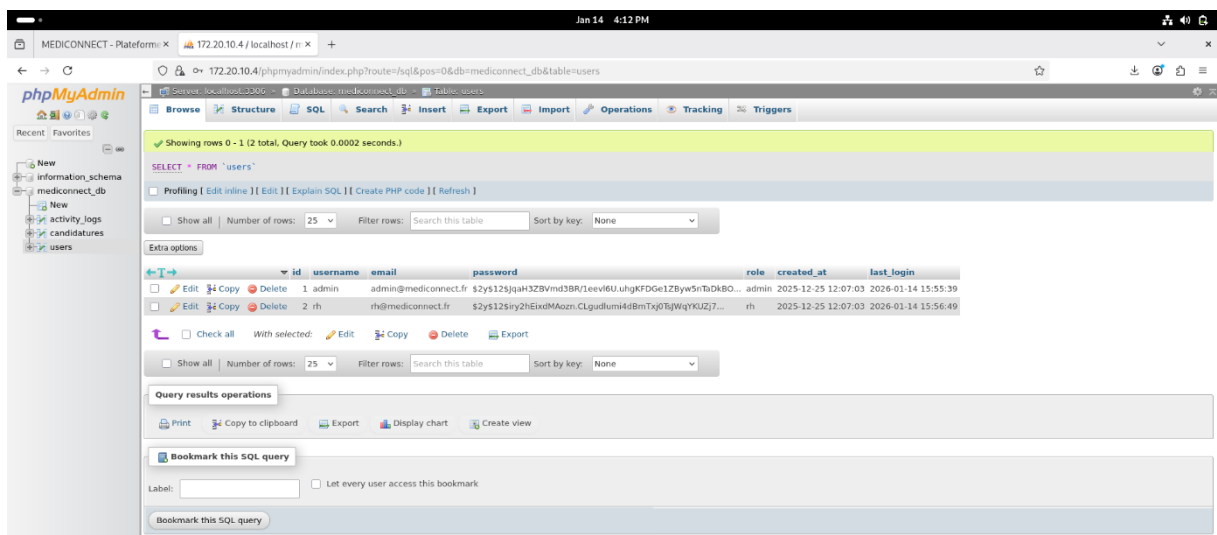
L'interface RH est similaire mais restreinte selon le principe de moindre privilège. Un bandeau précise l'accès en lecture seule. L'utilisateur RH peut consulter, visualiser les détails et télécharger les CV, mais ne peut ni modifier les statuts ni supprimer les candidatures. Les menus déroulants et boutons de suppression sont absents, cette limitation étant gérée au niveau PHP pour empêcher tout contournement.

4. Base de données et journalisation

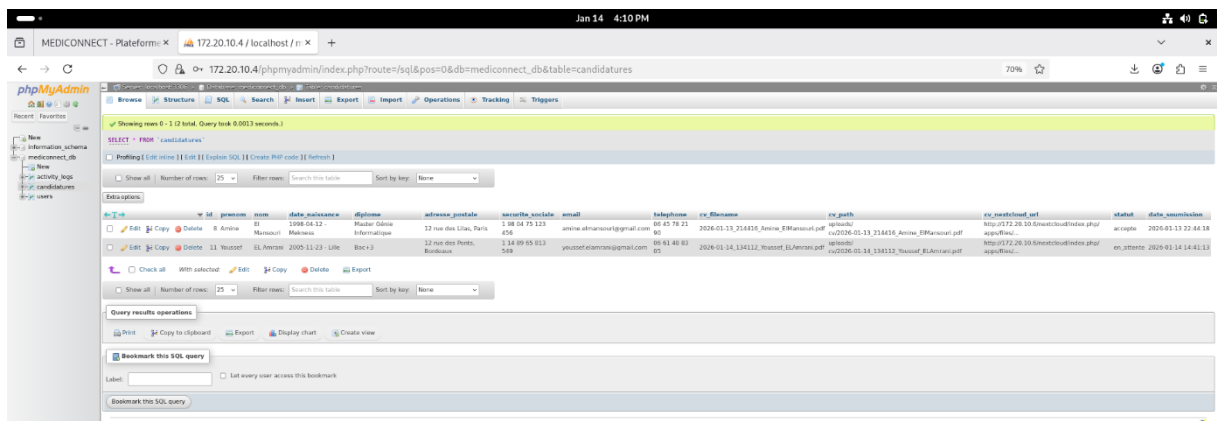
La base de données comprend trois tables :



- La table users : id (auto-incrémenté), username (unique), email (unique), password_hash, role (administrateur/ressources humaines), created_at, last_login.



- La table candidatures : id, prenom, nom, date_naissance, lieu_naissance, diplome, adresse, numero_secu, email, telephone, cv_filename, cv_path, statut, created_at.



- La table `activity_logs` : `id`, `user_id` (clé étrangère), `action_type`, `action_details`, `ip_address`, `created_at`. Cette table assure la traçabilité requise par le RGPD et permet de détecter des comportements anormaux. C'est dans cette table que le système enregistre toutes les actions sensibles : connexions réussies et échouées, déconnexions, téléchargements de CV, modifications de statut, suppressions et sauvegardes.

id	user_id	action	details	ip_address	created_at
1	1	LOGIN	Connexion réussie	127.0.0.1	2025-12-27 12:16:06
2	2	LOGIN	Connexion réussie	127.0.0.1	2025-12-27 12:16:54
3	1	LOGIN	Connexion réussie	127.0.0.1	2025-12-27 12:21:02
4	NULL	LOGIN_FAILED	Tentative de connexion avec utilisateur inexistant...	127.0.0.1	2025-12-27 23:05:46
5	2	LOGIN	Connexion réussie	127.0.0.1	2025-12-27 23:05:57
6	2	LOGOUT	Déconnexion	127.0.0.1	2025-12-27 23:06:07
7	1	LOGIN	Connexion réussie	127.0.0.1	2025-12-27 23:06:24
8	1	LOGOUT	Déconnexion	127.0.0.1	2025-12-27 23:06:30
9	1	LOGIN	Connexion réussie	127.0.0.1	2025-12-27 23:14:31
10	2	LOGIN	Connexion réussie	127.0.0.1	2025-12-27 23:15:05
11	1	LOGIN	Connexion réussie	127.0.0.1	2025-12-28 14:26:26
12	2	LOGIN	Connexion réussie	127.0.0.1	2025-12-28 14:26:30
13	1	LOGIN	Connexion réussie	127.0.0.1	2025-12-28 14:28:01
14	1	UPDATE_STATUS	Changement statut ID: 1 vers refuse	127.0.0.1	2025-12-28 14:28:08
15	1	UPDATE_STATUS	Changement statut ID: 1 vers en_attente	127.0.0.1	2025-12-28 14:28:13
16	1	UPDATE_STATUS	Changement statut ID: 1 vers en_attente	127.0.0.1	2025-12-28 14:37:56
17	1	UPDATE_STATUS	Changement statut ID: 1 vers en_attente	127.0.0.1	2025-12-28 14:38:20

5. Sécurisation

a. Mots de passe

Pour sécuriser les mots de passe, ils sont systématiquement hashés avant d'être enregistrés dans la base. Pour cela, on a utilisé l'algorithme `bcrypt` via `password_hash()` pour créer un hash sécurisé avec un sel unique (permet à deux mots de passe identiques de donner des hash différents). Lors de la connexion, `password_verify()` compare le mot de passe saisi au hash enregistré sans jamais exposer le mot de passe en clair. Cette méthode rend les attaques par force brut ou tables précalculées très difficiles.

password	role
\$2y\$12\$jqah3ZBVmd3BR/1eevl6U.uhgKFDGe1ZByw5nTaDkBO...	admin
\$2y\$12\$iry2hEixdMAozn.CLgudlumi4dBmTxj0TsJWqYKUZj7...	rh

b. Protection contre les injections SQL

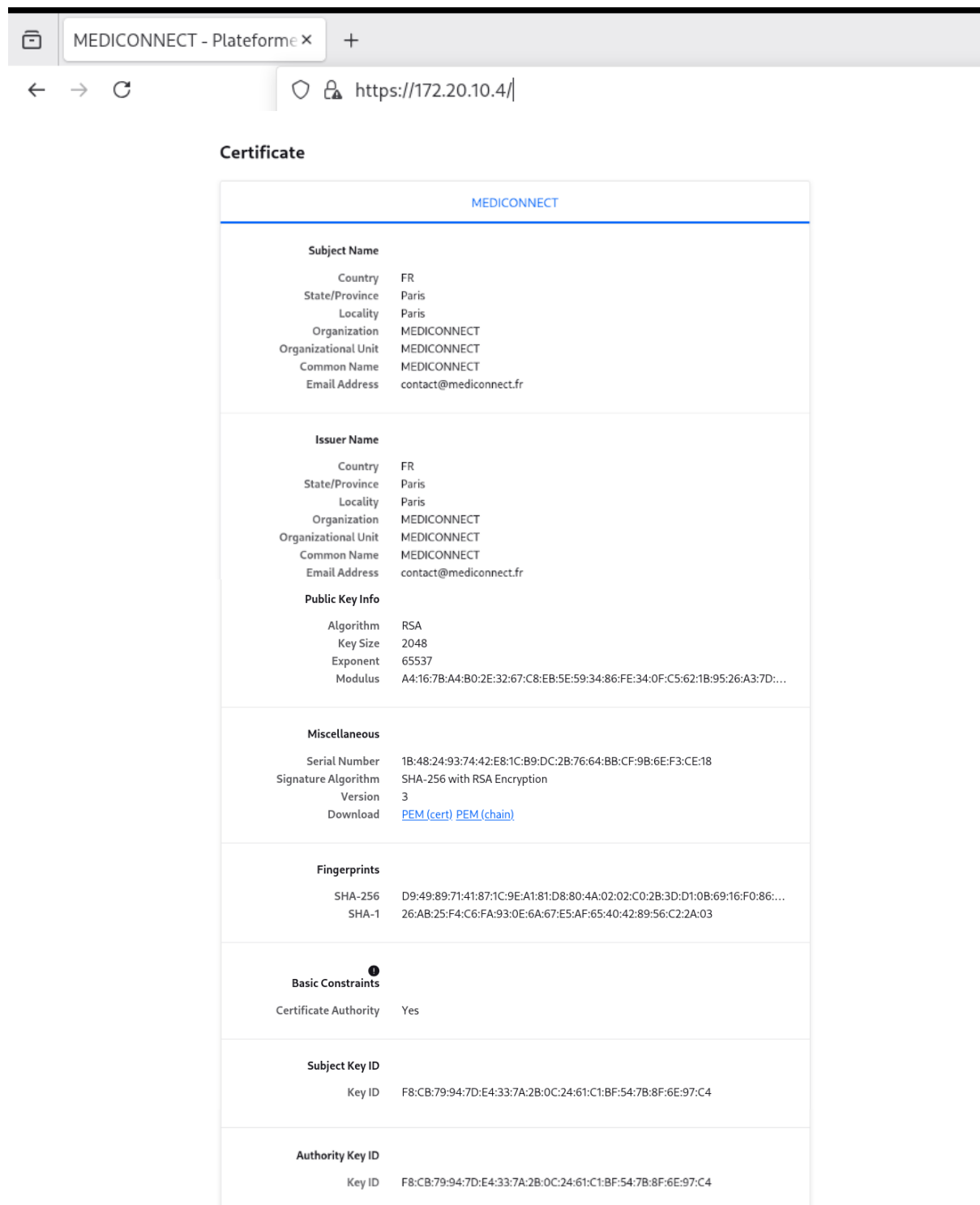
Pour se protéger des injections SQL, on utilise des requêtes préparées qui séparent la structure SQL des données utilisateur. La méthode `prepare()` retourne un objet `statement`, puis `bind_param()` associe les valeurs aux paramètres avec leur type (s pour string, i pour integer). Les données utilisateur sont traitées comme de simples valeurs, jamais comme du code exécutable pour empêcher toute exécution malveillante.

c. Validation et nettoyage des entrées

On vérifie et nettoie chaque donnée saisie avant de les traiter. Pour cela, on utilise `filter_var()` et `FILTER_VALIDATE_EMAIL` pour valider les mails, `trim()` pour supprimer les espaces inutiles, et `htmlspecialchars()` pour bloquer les tentatives de script (XSS) en convertissant les caractères spéciaux HTML en entités. Cela garantit qu'on traite seulement des données sûres.

d. Activation du protocole HTTPS

Pour protéger les données en transit (mots de passe, informations personnelles), le protocole HTTPS a été activé via TLS. Pour cela, on a généré un certificat auto-signé avec OpenSSL et configuré Apache pour activer le module SSL et utiliser ce certificat. Après avoir redémarré le serveur, l'application devient accessible via https au lieu de http. Le navigateur affiche un avertissement, normal pour un certificat auto-signé, mais le chiffrement fonctionne.



Certificate

MEDICONNECT

Subject Name	
Country	FR
State/Province	Paris
Locality	Paris
Organization	MEDICONNECT
Organizational Unit	MEDICONNECT
Common Name	MEDICONNECT
Email Address	contact@mediconnect.fr

Issuer Name	
Country	FR
State/Province	Paris
Locality	Paris
Organization	MEDICONNECT
Organizational Unit	MEDICONNECT
Common Name	MEDICONNECT
Email Address	contact@mediconnect.fr

Public Key Info	
Algorithm	RSA
Key Size	2048
Exponent	65537
Modulus	A4:16:7B:A4:B0:2E:32:67:C8:EB:5E:59:34:86:FE:34:0F:C5:62:1B:95:26:A3:7D:...

Miscellaneous	
Serial Number	1B:48:24:93:74:42:E8:1C:B9:DC:2B:76:64:BB:CF:9B:6E:F3:CE:18
Signature Algorithm	SHA-256 with RSA Encryption
Version	3
Download	PEM (cert) PEM (chain)

Fingerprints	
SHA-256	D9:49:89:71:41:87:1C:9E:A1:81:D8:80:4A:02:02:C0:2B:3D:D1:0B:69:16:F0:86:...
SHA-1	26:AB:25:F4:C6:FA:93:0E:6A:67:E5:AF:65:40:42:89:56:C2:2A:03

Basic Constraints	
Certificate Authority	Yes

Subject Key ID	
Key ID	F8:CB:79:94:7D:E4:33:7A:2B:0C:24:61:C1:BF:54:7B:8F:6E:97:C4

Authority Key ID	
Key ID	F8:CB:79:94:7D:E4:33:7A:2B:0C:24:61:C1:BF:54:7B:8F:6E:97:C4

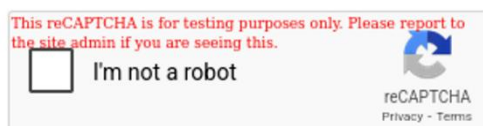
e. Séparation des serveurs et liaison avec Nextcloud

Comme mentionné dans la partie Installation Nextcloud, on a séparé physiquement le serveur d'application du serveur de stockage Nextcloud. Lorsqu'un CV est uploadé, il est vérifié puis envoyé vers Nextcloud via API sécurisée. L'URL unique est stockée dans cv_path. Pour télécharger, download-cv.php récupère l'URL, demande le fichier à Nextcloud et le transmet au navigateur.

Cette architecture apporte plusieurs avantages : la limitation de l'impact en cas de compromission, le chiffrement des données au repos par Nextcloud, les sauvegardes automatisées facilitées, et la préservation des CV même en cas de perte du serveur principal.

f. Captcha pour le login administrateur

Pour renforcer la sécurité contre les attaques par force brute et les tentatives automatisées, un système CAPTCHA a été ajouté à la page de connexion administrateur. Cette protection supplémentaire empêche les scripts malveillants de tenter des connexions répétées et garantit qu'un humain effectue la connexion.



VI. Rédaction du PIA

1. Contexte

La société MEDICONNECT souhaite mettre en place une plateforme sécurisée permettant aux candidats de déposer leur candidature pour les postes proposés dans l'entreprise. Ainsi, elle devra traiter des informations personnelles. En raison de cela, comme le conseille la CNIL, on établit une analyse d'impact sur la protection des données à caractère personnel concernant le processus de recrutement.

Responsable du traitement : M.Grospire

2. Principes fondamentaux

g. Finalités de traitement et pertinence des données collectées

Toutes les données collectées sont essentielles au processus de recrutement, et ne seront pas utilisées à d'autres fins. Celles-ci suivent [l'article 5 du RGPD](#).

- Pour s'adresser au candidat : nom, prénom
- Pour vérifier et différencier un candidat d'un autre : date et lieu de naissance
- Pour le contacter : téléphone, adresse mail, adresse postale
- Pour connaître son profil professionnel : CV, niveau de diplôme
- Pour établir le contrat de travail : numéro de sécurité sociale

h. Fondements du traitement

- Consentement : La personne concernée a consenti au traitement de ses données à caractère personnel (CV, etc).
- Exécution de mesures précontractuelles : Le traitement des données est nécessaire pour examiner la candidature et préparer un contrat de travail
- Respect d'une obligation légale : Certaines données comme le numéro de sécurité social sont nécessaires.
- Intérêts légitimes du responsable de traitements : pour recruter du personnel, et évaluer les compétences des candidats

i. Durée de conservation des données

- Si le candidat est retenu : les données sont ajoutées à la base de données des employés, et conservées conformément aux obligations légales.
- Si le candidat n'est pas retenu : suppression des données 1 an après le dernier contact, pour pouvoir le recontacter en cas de nouvelles opportunités.

j. Cycle de vie des données

1. Collecte des données via le formulaire
2. Stockage dans la base de données (MariaDB - serveur LAMP)
3. Traitement par le service RH
4. Conservation limitée
5. Suppression ou anonymisation des données

3. Les risques

Lors du processus de recrutement, il y a plusieurs risques concernant la protection des données à caractère personnel :

a. Accès illégitime à des données

Des tierces personnes pourraient obtenir un accès illégitime aux données des candidats, que ce soit par intrusion dans le système informatique de l'entreprise (piratage, malwares...) et par erreur humaine interne (partage involontaire, mauvaise configuration d'accès...). Dans ces cas, il y aurait une atteinte à la vie privée du candidat (divulgaration de données personnelles sensibles) ou un risque d'usurpation d'identité. Pour faire face à ce risque, on peut mettre en place des mesures initiales comme la restriction de l'accès des données, l'authentification forte, la journalisation des actions, et le chiffrement des échanges. On pourrait aussi améliorer l'architecture réseau en ajoutant un pare-feu.

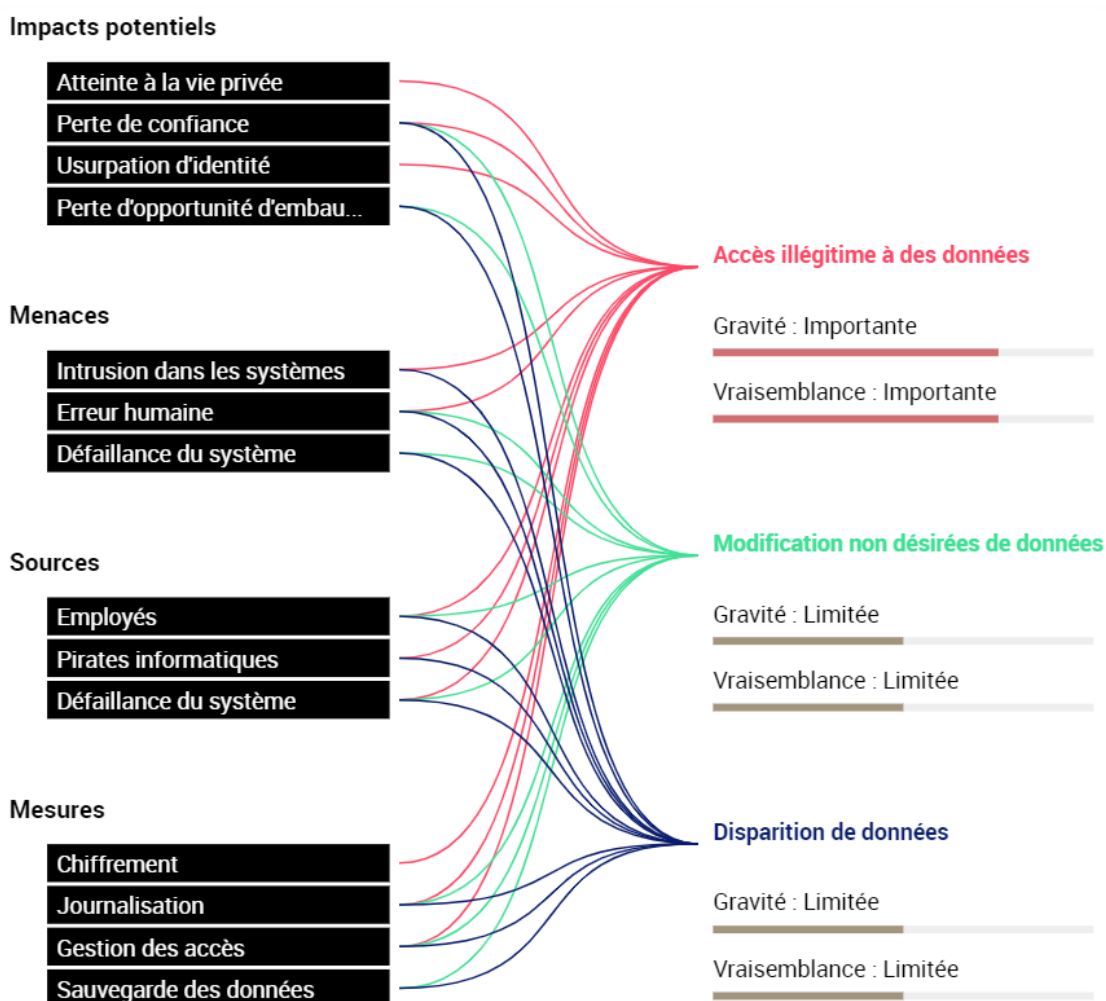
b. Modification non désirée des données

Des modifications non désirées des données des candidats peuvent survenir par erreur ou mauvaise interprétation, par exemple lorsqu'un candidat modifie une donnée en se basant sur une mauvaise compréhension ou supprime accidentellement des enregistrements essentiels sans en mesurer l'impact total. Parfois c'est à cause d'une erreur du système informatique (Virus, panne du serveur LAMP...). Ces erreurs peuvent entraîner des conséquences graves sur le candidat comme envoyer une candidature contenant des informations incorrectes ce qui influence sa candidature. Pour lutter contre cela, il est essentiel de mettre en place des mesures de contrôle d'accès rigoureuses. Parmi ces mesures on cite : la restriction de l'accès des données, la validation des modifications, la journalisation des actions, et les sauvegardes régulières.

c. Disparition de données

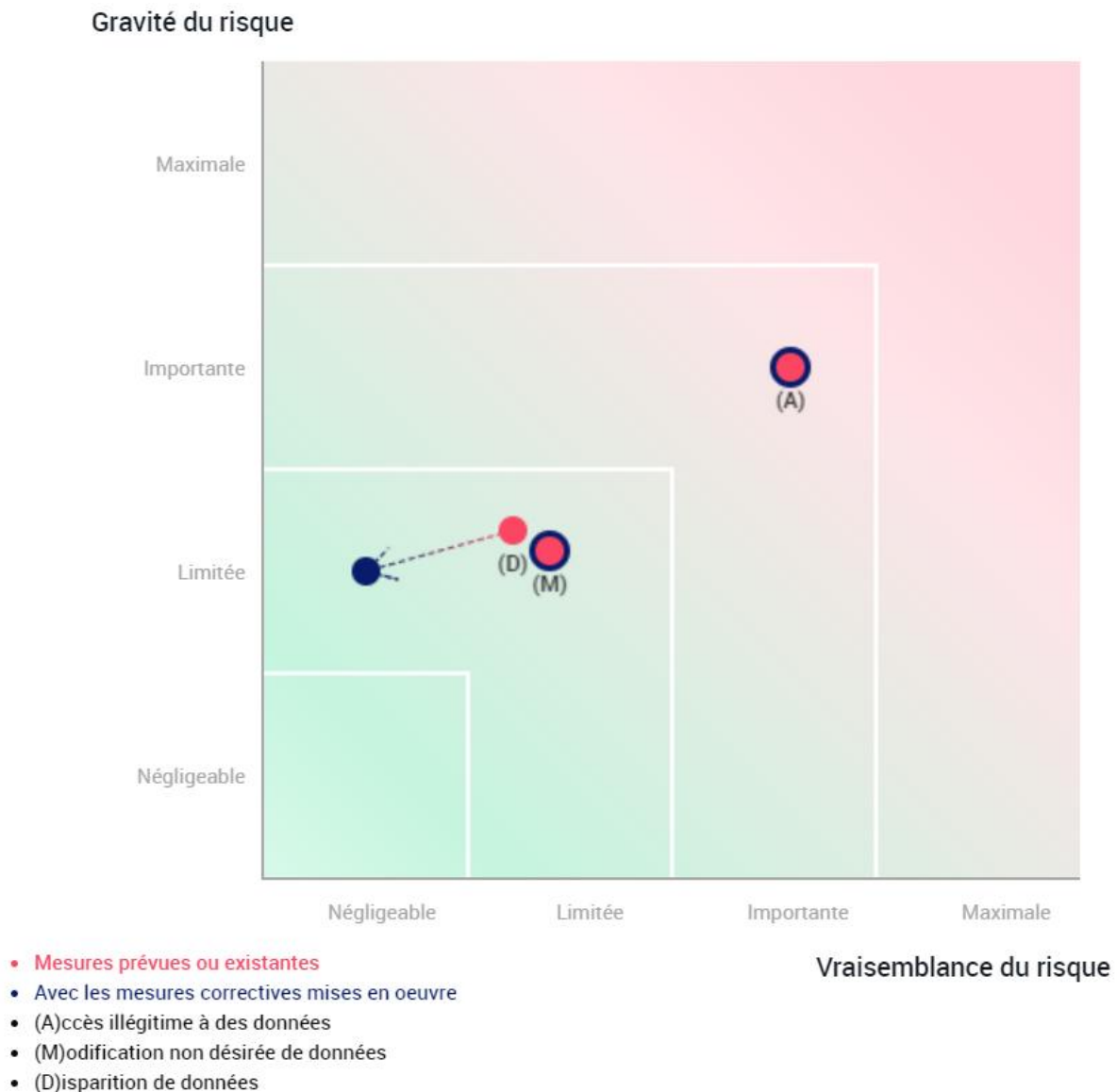
Les données peuvent être supprimées ou déplacées, que ce soit par erreur humaine, ou par erreur dans le système informatique (panne, problème de sauvegarde...). Cela aurait un impact sur le candidat qui perdrait sa candidature (perte d'opportunité d'embauche), mais aussi sur l'image de l'entreprise (perte de confiance). Pour faire face à ce risque, il faut restreindre l'accès aux données selon les rôles du personnel, sauvegarder automatiquement les données, dupliquer les serveurs, et faire une journalisation des accès.

Voici une vue d'ensemble des risques mentionnés :



4. La cartographie des risques

Le graphe montre l'évolution des 3 risques principaux avant et après l'application des mesures correctives.



- Avant la validation :
 - On avait un risque et une vraisemblance importante concernant l'accès illégitime des données (A) (zone rouge). En effet, le système n'étant pas encore totalement sécurisé, une intrusion ou un partage involontaire peut facilement se produire, avec des conséquences graves pour les candidats.
 - De la même manière, le risque de modification non désirée (M) et de disparition des données (D) existaient aussi, mais avec une probabilité et un impact moins important (limitée).
- Après la validation :
 - Le risque de disparition des données (D) devient négligeable au vu de l'ajout de mesures correctives importantes.

VII. Synthèse

Pour ce projet, on a mis en place une infrastructure réseau simple et fiable pour MEDICONNECT. L'objectif était de proposer un formulaire de candidature en ligne qui respecte au mieux le RGPD : on a adapté les droits d'accès, mis en place un système de journalisation, prévu des sauvegardes régulières pour éviter toute perte d'informations, et chiffré les échanges pour sécuriser les données.

Néanmoins, en faisant l'analyse d'impact PIA, on s'est rendu compte que notre solution n'est pas encore totalement conforme au RGPD. Par exemple, on collecte encore des infos comme le lieu de naissance, qui ne sont pas indispensables pour le recrutement. De plus, toutes les mesures prévues dans l'analyse d'impact ne sont pas encore toutes appliquées, ce qui laisse des points à renforcer.

Ce projet nous a vraiment montré que l'infrastructure réseau et la protection des données sont directement liée. Les mesures déjà mises en place réduisent les risques, mais il est nécessaire de poursuivre les efforts pour atteindre une conformité RGPD complète et garantir la protection des données.

Pour aller plus loin, on recommande au responsable du traitement et à la DSI de revoir les données collectées pour ne garder que l'essentiel, de mettre en œuvre toutes les mesures prévues dans l'analyse d'impact pour renforcer la sécurité (installation d'un pare-feu, duplication des serveurs...), de mettre à jour les systèmes, d'améliorer la gestion des accès pour tous les types d'employés, et de réaliser assez souvent des audits de sécurité pour anticiper les risques futurs.